Leaked ci-deployer key used to read the customer exports bucket

The access key of IAM user ci-deployer was pushed to a public repository on 2026-09-12 20:41 UTC. An external address used it 26 minutes later, created a backdoor user and read 1 090 objects (2.31 GB) of customer exports for July and August 2026. The client disabled the key on 2026-09-13 09:41 UTC; the actor made no successful call after that. The database password from the same file is not yet proven rotated.

CLIENT	INCIDENT	OPENED
Example Corp	inc-0042	2026-09-13T08:10Z
REPORT	**SEVERITY**	**STATUS**
2026-09-14 11:30Z	SEV-2	Contained
EVIDENCE UP TO	**SOURCES**	**LEAD**
2026-09-14 07:58Z	siem-demo · github audit export	Demo Analyst

26 min
from the public push to the first use of the key
w9 · w10

10.7 h
until the first GuardDuty finding
w13

12 h 34 min
the actor had access (dwell time)
w10 · w11

2.31 GB
read from exampleco-customer-exports
w7

1 214
API calls from 203.0.113[.]45
w4

01 Incident phases



Key public, not used yet · 26 min
Actor active, no alert · 10 h 44 min
Alert raised, key still active · 1 h 49 min
Key disabled, actor gets errors · 11 min

2026-09-12 20:41:37
dev-jlee pushes .env to the public repository `w9`

2026-09-12 21:07:44
First call from 203.0.113[.]45 `w10`

2026-09-13 07:52:00
First GuardDuty finding `w13`

2026-09-13 09:41:12
sec-admin sets the key to Inactive `w11`

2026-09-13 09:52:20
Last actor call, InvalidClientTokenId `w12`

Segment width is proportional to duration. Total 13 h 11 min.

02 Attack chain (MITRE ATT&CK)

INITIAL ACCESS
T1552.001
Credentials In Files
Key in a .env file of a public repository
`2026-09-12 20:41:37` `w9`

INITIAL ACCESS
T1078.004
Valid Accounts: Cloud Accounts
Calls signed with the ci-deployer key
`21:07:44` `w10`

DISCOVERY
T1087.004
Account Discovery: Cloud Account
GetCallerIdentity, 6 calls
`21:07` `w4`

DISCOVERY
T1619
Cloud Storage Object Discovery
ListBuckets 9, ListObjectsV2 61
`21:08–21:18` `w4`

PERSISTENCE
T1136.003
Create Account: Cloud Account
CreateUser svc-backup-sync
`21:19:10` `w5`

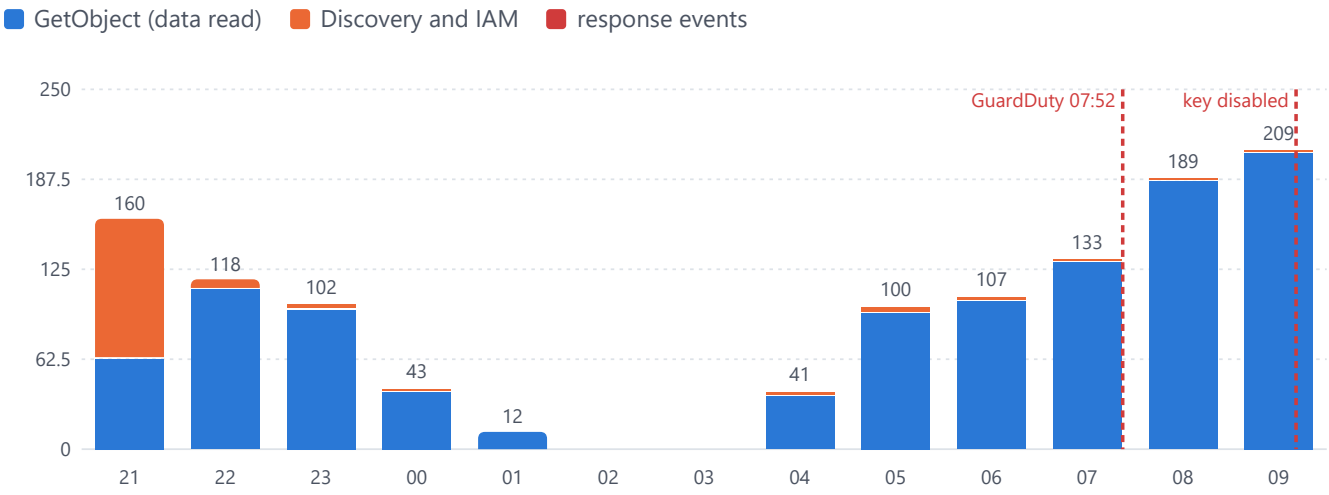
PERSISTENCE
T1098.001
Additional Cloud Credentials
CreateAccessKey for the new user
`21:19:31` `w5`

PRIVILEGE ESCALATION
T1098.003
Additional Cloud Roles
AttachUserPolicy AdministratorAccess, AccessDenied
`21:20:02` `w5`

COLLECTION
T1530
Data from Cloud Storage
1 090 GetObject, 2.31 GB
`21:24–09:38` `w7`

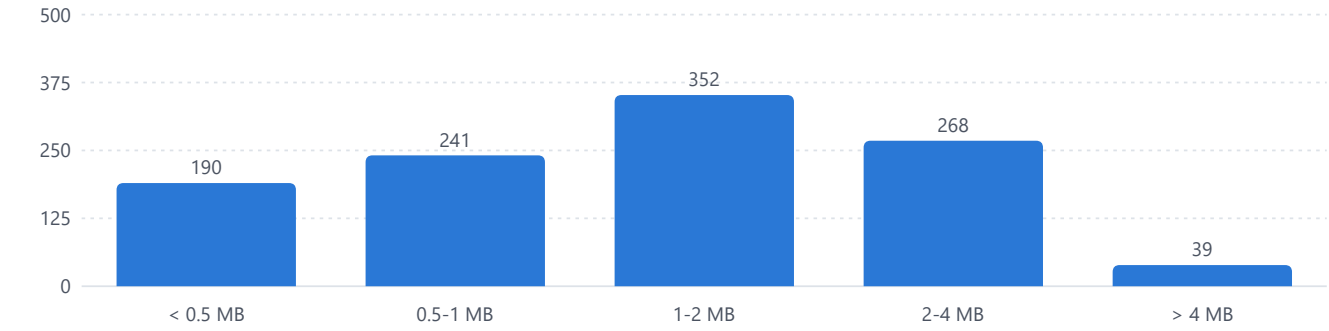
03 Activity and data

Actor API calls per hour (UTC)



2026-09-12 21:00 to 2026-09-13 09:59 UTC. No calls from 02:00 to 03:59. w15

Size of the objects read



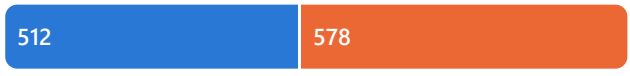
w16

Actor API calls by action

GetObject	1 090
ListObjectsV2	61
other	45
ListBuckets	9
GetCallerIdentity	6
CreateUser	1
CreateAccessKey	1
AttachUserPolicy (denied)	1

Linear scale. w4

Objects read by prefix

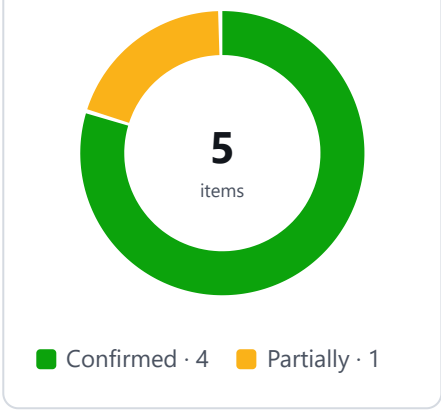


2026/07/ · 512 2026/08/ · 578

Every one of the 1 090 keys was read once. Other buckets cannot be checked (G2). w7 w8

04 Findings by plan item

#	QUESTION	STATUS	FACTS
01	Review exposure of the ci-deployer access key `analysis/item01_key_exposure.md`	Confirmed	2
02	Review the actor's API activity `analysis/item02_actor_activity.md`	Confirmed	4
03	Review persistence `analysis/item03_persistence.md`	Partially	4
04	Review data access in S3 `analysis/item04_s3_data_access.md`	Confirmed	3
05	Review containment `analysis/item05_containment.md`	Confirmed	4



05 Timeline (UTC)

2026-09-12 20:41:37	Push of a .env file with the ci-deployer key to the public repository. `w9` dev-jlee, example-corp/deploy-scripts
2026-09-12 21:07:44	First external call, GetCallerIdentity. `w10` ci-deployer, 203.0.113.45
2026-09-12 21:08–21:18	9 ListBuckets, 61 ListObjectsV2. `w4` ci-deployer, 203.0.113.45
2026-09-12 21:19:10	CreateUser svc-backup-sync, then CreateAccessKey at 21:19:31. `w5` ci-deployer, 203.0.113.45
2026-09-12 21:20:02	AttachUserPolicy AdministratorAccess denied. `w5` ci-deployer, 203.0.113.45
2026-09-12 21:24–2026-09-13 09:38	1 090 GetObject in exampleco-customer-exports/2026/, 2.31 GB. `w7` ci-deployer, 203.0.113.45
2026-09-13 07:52	First finding for ci-deployer from 203.0.113.45. `w13` GuardDuty
2026-09-13 07:58	Incident channel opened. `src` client platform team
2026-09-13 09:41:12	Key AKIA...EXMPL set to Inactive. `w11` sec-admin
2026-09-13 09:47:55	svc-backup-sync key and user deleted. `w11` sec-admin

2026-09-13 09:52:20 — Last actor call, InvalidClientTokenId. w12
203.0.113.45

2026-09-14 07:58 — Re-check: no actor events. w14
S1

Red marks a key actor event, green a response action.

06 Source coverage

SOURCE \ PLAN ITEM	01	02	03	04	05
S1 siem-demo cloudtrail / guardduty	w10	w3 w4 +2	G1 w5 +1	G2 w7 +2	w11 w12 +1
S2 github audit export	w9	n/a	n/a	n/a	n/a

w1 checked · G1 checked, part missing · n/a not applicable · G2 data missing · ? not checked

07 Indicators of compromise

TYPE	VALUE (DEFANGED)	FIRST SEEN UTC	SOURCE
IPv4	203.0.113[.]45	2026-09-12 21:07:44	S1 w10
IAM user (created by actor)	svc-backup-sync	2026-09-12 21:19:10	S1 w5
User agent	aws-cli/2.17.0 Python/3.11 Linux/6.5	2026-09-12 21:07:44	S1 w4

08 Exposed credentials

CREDENTIAL	HOW THE ACTOR GOT IT	USED BY ACTOR	ROTATED / REVOKED
IAM access key AKIA...EXMPL (user ci-deployer)	.env pushed to a public repository	yes: 1 214 calls (w4)	revoked — revoked: set Inactive 2026-09-13 09:41:12 (w11)
IAM access key of svc-backup-sync	created by the actor	no calls in eu-central-1 (w6)	deleted — deleted 2026-09-13 09:47:55 (w11)
Other secrets in the same .env (database URL)	same push	unknown	not visible

09 Data gaps and retention

ID	MISSING DATA	ITEMS	UNTIL THE SOURCE DELETES IT	STATUS
G1	CloudTrail for all regions except eu-central-1	03	87 d until 2026-12-11	requested requested 2026-09-13
G2	S3 server access logs for buckets other than exampleco-customer-exports	04	no known deadline	not available not available (client confirmed 2026-09-14: server access logging was off)
G3	GitHub organization audit log 2026-09-10 to 2026-09-14	01	no known deadline	received received 2026-09-14 (sources/client_export_2026-09-14/github_audit.jsonl)

Bar scale: 90 days. Red: 7 days or less.

10 Recommendations

PRIORITY	ACTION	WHY	OWNER	STATUS
Critical	Deactivate and delete the ci-deployer key	item02	Client	Done w11
Critical	Delete svc-backup-sync and its key	item03	Client	Done w11
Critical	Rotate the database password from the same .env	credentials #3	Client	Not visible in logs
High	Remove the .env from git history and enable push protection	item01	Client	Not checked

11 Evidence

Each claim of this report with the exact query and result from the worklog.

The actor made 1 214 calls from 203.0.113[.]45 Confirmed w4

w4 · 08:40 UTC · S1 siem

```
... WHERE source.ip == "203.0.113.45" | STATS MIN(@timestamp), MAX(@timestamp), COUNT(*) BY event.action | SORT COUNT(*) DESC
```

Result: 1 214 calls 2026-09-12 21:07:44 to 2026-09-13 09:38:02; GetObject 1 090, ListObjectsV2 61, ListBuckets 9, GetCallerIdentity 6, CreateUser 1, CreateAccessKey 1, AttachUserPolicy 1 (AccessDenied), other 45

26 minutes passed from the push to the first use of the key Confirmed w9 w10

w9 · 09:30 UTC · S2 github audit

```
log-profile.py sources/client_export_2026-09-14/github_audit.jsonl --where action~^git.push --where repo~deploy-scripts --keep @timestamp,actor,repo,action
```

Result: 1 push to example-corp/deploy-scripts 2026-09-12 20:41:37 by `dev-jlee`; repo public since 2025-11-02

w10 · 09:36 UTC · S1 siem

```
... WHERE aws.cloudtrail.user_identity.access_key_id == "AKIA...EXMPL" AND @timestamp >= "2026-09-12T20:41:37" | SORT @timestamp | LIMIT 1
```

Result: First external call 2026-09-12 21:07:44 from 203.0.113.45 (GetCallerIdentity)

The svc-backup-sync key was never used Partially w6

w6 · 09:03 UTC · S1 siem

```
... WHERE aws.cloudtrail.user_identity.user_name == "svc-backup-sync" | STATS COUNT(*) BY source.ip, event.action
```

Result: 0 events on a filled field (user_name filled in 100% of IAM user events, w2 window)

2.31 GB was read from 1 090 distinct objects Confirmed w7 w8

w7 · 09:15 UTC · S1 siem

```
FROM logs-aws.cloudtrail-* | WHERE event.action == "GetObject" AND source.ip == "203.0.113.45" | STATS COUNT_DISTINCT(aws.s3.object.key), SUM(aws.cloudtrail.additional_eventdata.bytes_transferred_out)
```

Result: 1 090 GetObject on 1 090 distinct keys, 2.31 GB out, all in `exampleco-customer-exports/2026/`

w8 · 09:24 UTC · S1 siem

```
... WHERE event.action == "GetObject" AND source.ip == "203.0.113.45" | STATS COUNT(*) BY aws.s3.object.key_prefix
```

Result: `2026/07/` 512, `2026/08/` 578

The actor is locked out Confirmed w11 w12 w14

w11 · 09:44 UTC · S1 siem

```
... WHERE event.action IN ("UpdateAccessKey","DeleteAccessKey","DeleteUser") AND @timestamp >= "2026-09-13"
```

Result: UpdateAccessKey Inactive `AKIA...EXMPL` 09:41:12 by `sec-admin`; DeleteAccessKey + DeleteUser `svc-backup-sync` 09:47:55

w12 · 10:30 UTC · S1 siem

```
... WHERE source.ip == "203.0.113.45" AND @timestamp > "2026-09-13T09:41:12" | STATS COUNT(*) BY event.action, aws.cloudtrail.error_code
```

Result: 3 calls after deactivation, all `InvalidClientTokenId`; none after 09:52:20

w14 · 11:05 UTC · S1 siem

```
FROM logs-aws.cloudtrail-* | WHERE source.ip == "203.0.113.45" AND @timestamp > "2026-09-13T09:52:20"
```

(re-run at 2026-09-14 08:00)

Result: 0 events; newest event in source 2026-09-14 07:58

12 Method and limits

SOURCE	TYPE	COVERS
siem-demo	siem	CloudTrail management events eu-central-1, S3 data events for `exampleco-customer-exports`, GuardDuty
github audit export	file	Organization audit log 2026-09-10 to 2026-09-14

- All times are UTC.
- Indicators are defanged; secrets are never included.
- Item statuses: Confirmed, Partially, Not determinable, Discarded.
- A negative result counts only on a field that is filled in the source and window checked.
- CloudTrail in the SIEM covers eu-central-1 only (G1).
- S3 data events exist for one bucket only (G2).
- Data we could not check:
  - G1: CloudTrail for all regions except eu-central-1 (requested)
  - G2: S3 server access logs for buckets other than exampleco-customer-exports (not available)

All times UTC Indicators defanged Generated by ir-casekit report.py from the case files